

ARQUITETURA DE DEFESA EM BLOCKCHAIN

Julia Martins Pereira ⁽¹⁾, Claus Cornelio dos Santos Filho ⁽²⁾, Giovanna Oliveira de Jesus ⁽³⁾, Igor Sergio dos Santos ⁽⁴⁾
Nathan Ferreira Neves ⁽⁵⁾ Orientador: Prof. Me. José Picovsky. ⁽¹⁾ 7-ENGGCOMP-00349371, ⁽²⁾ 7-ENGGCOMP-00350915,
⁽³⁾ 7-ENGGCOMP-00349647, ⁽⁴⁾ 7-ENGGCOMP-00343234 ⁽⁵⁾ 7-ENGGCOMP-00350327.

RESUMO

O artigo analisa o desenvolvimento de uma arquitetura de defesa cibernética fundamentada em tecnologia *blockchain* para assegurar a integridade e a imutabilidade de registros em sistemas corporativos de saúde. O cenário de crescente digitalização hospitalar expõe dados críticos a vulnerabilidades em infraestruturas centralizadas, as quais sofrem ameaças constantes de manipulação e ataques automatizados. A solução proposta estabelece uma camada de proteção híbrida que utiliza interfaces de programação de aplicações (API) para interceptar eventos em sistemas legados e ancorar resumos criptográficos (*hashes*) via algoritmo SHA-256 em uma rede descentralizada. Para validar a eficácia do modelo sem comprometer a estabilidade operacional, adota-se uma metodologia de simulação por meio de *Honeypot*, utilizando o contexto técnico de um Hospital como cliente piloto. Os resultados demonstram que a utilização de Árvores de *Merkle* e protocolos de segurança em camadas otimiza os custos transacionais e garante a conformidade com a Lei Geral de Proteção de Dados (LGPD). Conclui-se que a arquitetura proposta cria uma trilha de auditoria imutável e auditável, eliminando pontos únicos de falha e elevando o patamar de confiabilidade e segurança da informação em ecossistemas hospitalares de alta complexidade.

Palavras-Chave: Blockchain; Cibersegurança; Auditoria Digital; LGPD; Sistemas Hospitalares.

1. Introdução

A Crise do *Software*, surgida no final da década de 1960, representou um período de instabilidade em que a indústria não conseguia entregar sistemas confiáveis, resultando em atrasos crônicos, orçamentos estourados e falhas graves. Esse cenário foi impulsionado pelo descompasso entre a rápida evolução do *hardware* e o atraso nas técnicas de programação, além de uma demanda por sistemas cada vez mais complexos que superam a capacidade dos métodos artesanais da época. Sem padrões ou métodos consolidados, o desenvolvimento dependia excessivamente do estilo individual de cada programador, o que gerava sistemas frágeis e de difícil manutenção [1].

Como resposta a esse caos, nasceu a Engenharia de *Software*, que introduziu uma abordagem sistemática e disciplinada ao setor, estabelecendo processos estruturados, ciclos de vida de projeto, documentação rigorosa e testes de qualidade para garantir a eficiência e a confiabilidade dos sistemas modernos.

Nos dias atuais os sistemas necessitam da proteção de dados, que por sua vez, consolidou-se pela necessidade de garantir a continuidade operacional, motivada por ataques capazes de paralisar empresas inteiras. Historicamente, a *Cybersecurity* surge quando a informação se torna o ativo mais valioso do mercado, exigindo barreiras que vão além de normas burocráticas [1,2].

O perigo torna-se ainda mais crítico com a evasão de detecção, técnica que permite a *malwares* possam contornar protocolos de segurança, como antivírus e *firewalls* comprometendo diretamente a autonomia técnica dos desenvolvedores e a visão estratégica dos executivos. O senso comum de que a segurança "atrapalha" o trabalho é um equívoco; esse atrito geralmente ocorre quando as barreiras de proteção são inseridas de forma improvisada para remediar falhas em sistemas já vulneráveis. São essas correções reativas que obstruem os fluxos de desenvolvimento e gestão.

Como o controle de dados críticos por terceiros representa um risco irreversível à sobrevivência corporativa, o *Blockchain* surge como um elemento de blindagem essencial. Ele reforça as camadas de segurança tradicionais por meio de uma camada de imutabilidade algorítmica [3]. Essa estratégia assegura que a integridade dos dados seja mantida independentemente de tentativas de evasão ou força bruta, convertendo o fluxo de informações em um registro permanentemente auditável e imune a manipulações maliciosas.

2. Metodologia

A pesquisa fundamenta-se em uma abordagem qualitativa e exploratória, utilizando o método de engenharia experimental para validar a eficácia da arquitetura proposta. Baseando-se em uma revisão bibliográfica densa sobre Tecnologias de Registro Distribuído (DLT) e no desenvolvimento de um protótipo funcional para a simulação de processos de auditoria imutável. Foi utilizado um ambiente controlado baseado no método de cibersegurança *Honeypot*, simulando um servidor corporativo para observar o comportamento da camada de defesa. Esta simulação permite testar a integração de interfaces via API sem comprometer dados produtivos reais. A base metodológica

consiste no estudo de protocolos de consenso e na criação de um artefato técnico (protótipo) para verificar a comunicação entre sistemas legados e redes descentralizadas. O objetivo central reside no desenvolvimento de uma arquitetura de proteção de dados que utiliza a DLT para garantir a integridade das informações provenientes do servidor simulado.

A metodologia prevê a decomposição técnica das estruturas de dados utilizadas para garantir a segurança. O processo inicia com a aplicação do algoritmo de *hashing* SHA-256 sobre registros originários do sistema simulado, transformando informações de tamanho variável em sequências alfanuméricas fixas de 64 caracteres. A pesquisa analisa o princípio do encadeamento criptográfico, no qual cada bloco de informação carrega o *hash* do bloco precedente, estabelecendo uma dependência cronológica e lógica. Este mecanismo é fundamental para garantir a imutabilidade, uma vez que qualquer alteração em um dado histórico rompe o elo matemático da corrente, permitindo a detecção imediata de fraudes por meio de um efeito dominó digital.

A modelagem estrutural divide-se em quatro camadas interdependentes para assegurar a modularidade da solução. A primeira camada compreende o sistema corporativo (SaaS ou ERP), que permanece inalterado em sua lógica interna. A segunda camada consiste em uma API intermediária, desenvolvida em linguagens como *Node.js* ou *Python*, responsável por interceptar eventos críticos e gerar a "impressão digital" (*hash*) do dado. A terceira camada gerencia a interface com a rede *blockchain*, utilizando bibliotecas como *ethers.js* ou *web3.js* para assinar transações digitalmente. Por fim, a quarta camada operacionaliza o contrato inteligente (*smart contract*), escrito em linguagem *Solidity*, que governa as regras de registro e consulta das provas de integridade. Este fluxo garante que apenas o *hash* seja enviado para a rede, preservando a confidencialidade do dado original.

A investigação de viabilidade avalia o equilíbrio entre segurança, custo operacional e desempenho. A pesquisa analisa a utilização de Redes de Camada 2 (L2), como *Polygon* ou *Optimism*, visando reduzir as taxas de transação e tornar o projeto sustentável para o cenário corporativo. A validação da implementação ocorre através de testes de auditoria sob demanda, nos quais a API confronta o estado atual do dado no simulador com o *hash* ancorado na *blockchain*. Esta análise permite mensurar a eficácia da arquitetura na mitigação de ataques de alteração de registros e na criação de trilhas de auditoria permanentes, independentes da autoridade central do fornecedor de *software*.

3. Desenvolvimento

Com a intensificação do uso de sistemas digitais nas organizações, os ataques cibernéticos tornaram-se mais avançados e de difícil detecção. Nesse cenário, os *logs* de atividades assumem um papel fundamental na segurança da informação e no atendimento a normativas regulatórias, como a Lei Geral de Proteção de Dados Pessoais (LGPD). Contudo, em arquiteturas tradicionais, esses registros permanecem vulneráveis à manipulação por invasores que obtêm escalação de privilégios, comprometendo a confiabilidade das auditorias [4]. A urgência por proteção acelera-se com o advento das Inteligências Artificiais (IAs), que sofisticam os vetores de engenharia social e automatizam a busca por vulnerabilidades de forma massiva e quase instantânea [6]. Como contramedida, a tecnologia *blockchain* emerge como uma alternativa robusta. Sua principal característica reside na aplicação de funções criptográficas de *hash* (figura 1), que transformam dados de tamanhos variados, como senhas ou arquivos completos, em sequências exclusivas de caracteres com comprimento fixo, atuando como uma assinatura digital unívoca do registro [10]. A segurança desta arquitetura fundamenta-se na descentralização e na distribuição do controle de validação, eliminando a figura de um ponto único de falha. A imutabilidade é garantida por mecanismos de consenso e criptografia assimétrica (chaves públicas e privadas), que tornam os registros permanentes e resistentes a exclusões não autorizadas [11, 12]. A partir dessa estrutura criptográfica, constrói-se um mecanismo lógico onde cada bloco de informação carrega obrigatoriamente o *hash* do bloco anterior [10] (Figura 2). Consequentemente, qualquer tentativa de modificar um dado histórico altera o seu *hash* resultante, quebrando o encadeamento e evidenciando o sinal de adulteração para toda a rede de forma imediata [11].



Figura 1: Funções Hash e Merkle Root.

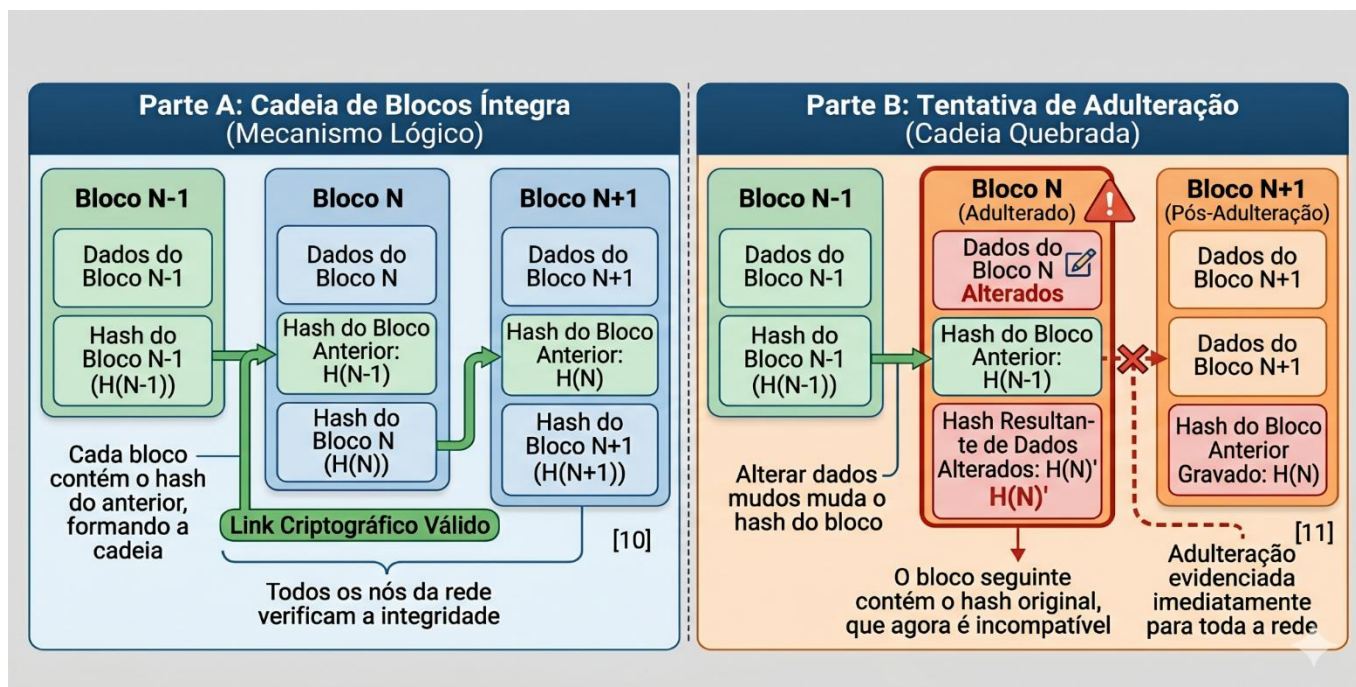


Figura 2: Mecanismo de Encadeamento Criptográfico e Integridade da Blockchain.

Para validar a aplicabilidade deste modelo além do ambiente estritamente teórico, a pesquisa contou com a parceria da empresa *Nice Drinks*, indústria atuante no segmento de bebidas alcoólicas congeladas e na manufatura de maquinários de produção variados. A corporação atuou como parceira tecnológica para o projeto, disponibilizando seu banco de dados estruturado para a execução dos testes práticos da API e a verificação do funcionamento da esteira criptográfica. A homologação do sistema neste ambiente operacional permitiu testar a escalabilidade e o comportamento da rede em cenários reais, assegurando o refinamento da arquitetura e garantindo uma abordagem tecnológica mais assertiva, madura e estável para a futura implantação na instituição do setor hospitalar com a qual a pesquisa mantém tratativas.

No contexto de trilhas de auditoria (*Audit Trail*), sistemas tradicionais permitem que administradores mal-intencionados apaguem rastros de invasão. Em contrapartida, na *blockchain*, toda interação de acesso, alteração ou exclusão é tratada como uma transação imutável [3]. Esta característica facilita substancialmente as auditorias de conformidade com a LGPD, criando processos sistemáticos que atestam a adesão legal e mitigam riscos. Entretanto, o armazenamento *on-chain* de informações sensíveis esbarra no "direito ao esquecimento" garantido por lei, uma vez que a *blockchain* não permite deleção.

Para solucionar este conflito, especialmente crítico em ambientes de alta sensibilidade como o setor hospitalar, a arquitetura adota um modelo híbrido (*Off-chain*). Os dados sensíveis de saúde e identificação permanecem armazenados nos bancos de dados locais e protegidos da instituição. Em total alinhamento com a fase de descoberta do projeto, que foca na modelagem analítica e arquitetural em detrimento de implantações diretas de código, a solução estruturou o fluxo lógico em duas fases operacionais distintas: a validação interna e a ancoragem externa. Na fase de auditoria interna da arquitetura proposta, a modelagem estabelece que o sistema legado lê os prontuários, gera os *hashes* individuais (SHA-256) e compõe a Árvore de *Merkle*, permitindo a verificação de integridade localmente. Apenas após a confirmação de conformidade nesta etapa primária, o fluxo analítico habilita a fase externa.

Neste momento projetado, o *Merkle Root* consolidado recebe uma assinatura digital baseada em criptografia assimétrica (RSA) com a chave privada exclusiva da instituição, assegurando a prova irrefutável de autoria. Em seguida, este pacote lógico é transmitido para a rede *blockchain* pública (como a *Ethereum*), que atua como cartório digital, retornando o *tx_hash* para selar a imutabilidade temporal do registro. Apesar dos benefícios evidentes, a integração de redes distribuídas em infraestruturas de saúde impõe o desafio de identificar a origem de manipulações. A *blockchain* atua com precisão para detectar que uma alteração indevida ocorreu no banco de dados.

Contudo, para tornar a solução plenamente aderente às necessidades de *compliance*, o desenho arquitetural incorporou um Módulo de Auditoria Avançada voltado ao rastreamento de *logs* médicos. Este módulo analítico opera sob criptografia AES e acesso restrito aos gestores de segurança da informação, registrando e apontando quem realizou a alteração, quando e a partir de qual terminal. Esta combinação confere à arquitetura a

capacidade de não apenas evidenciar a quebra da cadeia criptográfica, mas também fornecer o rastro de auditoria completo para investigações internas.

Adicionalmente, a validação analítica destas arquiteturas de segurança exige cautela para não expor a infraestrutura real a riscos. A modelagem por meio da simulação em ambiente isolado (*HoneyPot*) atesta a viabilidade teórica da comunicação entre o sistema legado e a rede descentralizada de forma segura, preparando o terreno para futuras etapas de desenvolvimento e implantação em cenários reais de aplicação corporativa (Figura 3).

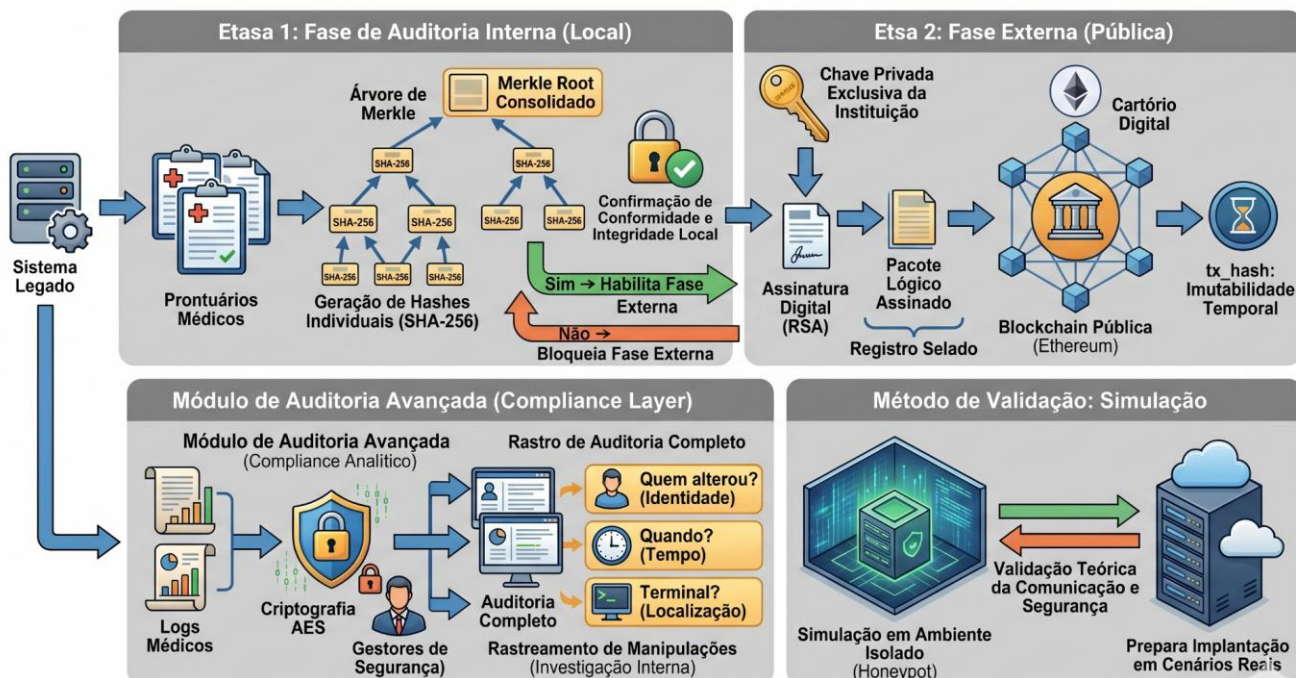


Figura 3: Arquitetura de Defesa Híbrida e Módulo de Auditoria Avançada.

4. Considerações Finais

A etapa inicial desta pesquisa, materializada no desenvolvimento do protótipo em PHP e MySQL, evidencia que a implementação de uma arquitetura de defesa baseada em Tecnologias de Registro Distribuído (DLT) representa um avanço tangível para a segurança cibernética em ambientes hospitalares. Ao revisar os objetivos propostos, observa-se que a solução estruturada é capaz de mitigar falhas críticas de integridade sem comprometer a confidencialidade exigida pela Lei Geral de Proteção de Dados.

A divisão do fluxo sistêmico entre validação interna e ancoragem externa demonstrou profundo alinhamento com as práticas de governança corporativa. O modelo atesta que a instituição mantém controle absoluto sobre a aprovação de suas auditorias antes que qualquer prova criptográfica seja assinada via protocolo RSA e enviada à rede pública. Os resultados do protótipo confirmam que o agrupamento de logs por meio de Árvores de Merkle, somado ao módulo de auditoria avançada com criptografia, resolve o conflito entre a permanência dos registros *on-chain* e a necessidade de investigação direcionada para rastrear a autoria de alterações no banco de dados local.

Quanto à avaliação da proposta, destaca-se que a homologação prática e os testes experimentais da API foram viabilizados por meio da colaboração com a empresa *Nice Drinks*, indústria atuante no segmento de bebidas alcoólicas congeladas e na manufatura de maquinários. A corporação cedeu seu banco de dados estruturado para atuar como ambiente piloto, permitindo a validação da esteira criptográfica da API em um cenário operacional de mercado. Convém ressaltar que a pesquisa manterá uma trajetória contínua de crescimento e progressão técnica ao longo dos próximos semestres. Esta evolução cronológica acompanhará o andamento dos trâmites burocráticos necessários para a obtenção do aceite formal definitivo junto à instituição de saúde à qual o sistema foi originalmente direcionado e desenvolvido. Avalia-se que, com este planejamento, a fundamentação na Engenharia de Software é plenamente respeitada, garantindo um ciclo de vida de projeto disciplinado e focado na qualidade do produto final.

Como desenvolvimentos futuros para os próximos semestres do Projeto Final de Curso (PFC), propõe-se a expansão do painel de *dashboards* executivos para a análise gráfica de períodos fraudados e íntegros, bem como a avaliação de desempenho da solução em redes corporativas permissionadas, como a *Hyperledger*, visando otimizar os custos transacionais em larga escala.

5. Referências

- [1] **Pressman RS, Maxim BR.** Engenharia de software: uma abordagem profissional. 8ª ed. Porto Alegre: AMGH; 2016.
- [2] **Naur P, Randell B,** editores. Software engineering: report of a conference sponsored by the NATO Science Committee; 1968 Oct 7-11; Garmisch, Germany. Brussels: Scientific Affairs Division, NATO; 1969. Disponível em: <http://homepages.cs.ncl.ac.uk/brian.randell/NATO/nato1968.PDF>
- [3] **Petroni BCA, Gonçalves RF.** Smart Contracts baseados em blockchain na cadeia de custódia digital: uma proposta de arquitetura. In: Proceedings of International Conference on Forensic Computer Science and Cyber Law (ICoFCS); 2018. p. 23-30. Disponível em: <http://icofcs.org/2018/ICoFCS-2018-003.pdf>
- [4] **Breviário AG, Quesada MRS, Rebello FAS, Vidal RLS, Oliveira Filho AS.** COMO A INTELIGÊNCIA ARTIFICIAL PODE GERAR NOVAS AMEAÇAS E TAMBÉM APRIMORAR A CIBERSEGURANÇA NAS EMPRESAS. Revista Eletrônica Multidisciplinar de Investigação Científica. 2025;4(21).
- [5] **Kalakuntla R. Cyber Security. Holistica.** 2019;10(2):115-128. doi: 10.2478/hjbpa-2019-0020.
- [6] **Lehto M, Neittaanmäki P,** editores. Cyber Security: Policy and Technology. Studies in Big Data, vol. 183. Cham: Springer; 2026. doi: 10.1007/978-3-032-08890-1.
- [7] **Meinel C, Gayvoronskaya T.** Blockchain: Hype oder Innovation. Springer Berlin Heidelberg; 2020. doi: 10.1007/978-3-662-61916-2.
- [8] **Buterin V. Ethereum: A Next-Generation Smart Contract and Decentralized Application Platform.** White Paper; 2013.
- [9] **Nakamoto S.** Bitcoin: A Peer-to-Peer Electronic Cash System; 2008.
- [10] **Swan M.** Blockchain: Blueprint for a New Economy. Sebastopol: O'Reilly Media; 2015.
- [11] **Tapscott D, Tapscott A.** Blockchain Revolution: How the Technology Behind Bitcoin Is Changing Money, Business, and the World. New York: Portfolio; 2016.
- [12] Brasil. Lei nº 13.709, de 14 de agosto de 2018. Lei Geral de Proteção de Dados Pessoais (LGPD). Diário Oficial da União. 15 ago 2018.
- [13] **Microsoft.** O que é proteção de dados? [Internet]. Redmond: Microsoft Security; [citado em 2026]. Disponível em: <https://www.microsoft.com/pt-br/security/business/security-101/what-is-data-protection>
- [14] Instituto Brasileiro de Defesa do Consumidor (IDEC). Proteção de Dados [Internet]. São Paulo: IDEC; [citado em 2026]. Disponível em: <https://idec.org.br/dicas-e-direitos/protecao-de-dados>
- [15] **IBM.** O que é a proteção de dados? [Internet]. Armonk: IBM; [citado em 2026]. Disponível em: <https://www.ibm.com/br-pt/think/topics/data-protection>
- [16] **Tadi V.** Quantitative Analysis of AI-Driven Security Measures: Evaluating Effectiveness, Cost-Efficiency, and User Satisfaction Across Diverse Sectors. Journal of Scientific and Engineering Research. 2024;11(4):328-343. Disponível em: <https://www.sciencedirect.com/science/article/pii/S2772918423000188>
- [17] **Dumbrava D.** Cyber Security [Internet]. 2012 [citado em 2026]. Disponível em: <https://dumitrudumbrava.wordpress.com/wp-content/uploads/2012/01/cyber-security.pdf>
- [18] Cibersegurança [Internet]. IEEE Xplore; [citado em 2026]. Disponível em: <https://ieeexplore.ieee.org/abstract/document/1201257>
- [19] O que é Blockchain [Internet]. IEEE Xplore; [citado em 2026]. Disponível em: <https://ieeexplore.ieee.org/abstract/document/8024092>
- [20] Understanding Blockchain Technology [Internet]. [citado em 2026]. Disponível em: https://d1wqtxts1xzle7.cloudfront.net/60715489/Understanding_Blockchain_Technology20190926-26770-147v9qi-libre.pdf